

Instructor Guide — Human, Physical & Process Attack Surface

Solo docente — scenario fittizio.

Questo documento serve a guidare la discussione sul pensiero offensivo senza trasformare la lezione in una raccolta di trucchi. Le tecniche sono descritte a livello concettuale e vanno trattate come ipotesi da validare esclusivamente in ambienti autorizzati.

Rilascio a ondate

Non consegnare più il vecchio dossier unico. Usare:

```
Wave 1
01-company-overview.md
02-org-roles.md

Wave 2
03-interview-notes.md
04-site-observation.md

Wave 3
05-operating-calendar.md
06-controls-and-policy-excerpts.md
07-public-footprint.md
```

Tra una wave e la successiva gli studenti devono aggiornare il proprio modello.

La domanda non è:

"Avete trovato un'altra vulnerabilità?"

ma:

"Quale vostra convinzione è cambiata con le nuove informazioni?"

Usare il budget di [assessment-decision-board.md](#) soltanto dopo Wave 3. Prima devono imparare a convivere con l'incertezza.

Come usare il dossier senza suggerire le risposte

Il dossier studenti è volutamente scritto come materiale di discovery e **non** come catalogo di debolezze.

Non introdurre il documento con:

"Cercate i punti attaccabili."

Usare invece:

"Leggete queste informazioni come se arrivassero da interviste e osservazioni di un cliente. Decidete quali meritano una domanda in più."

La progressione deve essere:

```
DETTAGLIO
  ↓
È UN FATTO O UNA DICHIARAZIONE?
  ↓
MI MANCA QUALCOSA?
  ↓
PERCHÉ POTREBBE CONTARE?
  ↓
SOLO DOPO: IPOTESI DI ATTACCO
```

Non suggerire parole come *tailgating*, *phishing*, *USB drop*, *dumpster diving*, *BEC* o *credential attack* finché non sono gli studenti a formulare il concetto.

Se uno studente propone immediatamente una tecnica, chiedere:

```
Quale dettaglio del dossier ti ha portato lì?
Quali passaggi intermedi stai assumendo?
Quale di questi passaggi non hai ancora dimostrato?
```

Il documento contiene intenzionalmente:

- indizi utili;
- informazioni incomplete;
- dettagli normali;
- falsi lead;
- controlli compensativi;
- elementi che richiederebbero troppo sforzo.

L'obiettivo non è premiare chi inventa più attacchi, ma chi **seleziona meglio le ipotesi**.

Obiettivo

Gli studenti devono imparare che una superficie di attacco comprende:

```
technical
human
physical
process
identity
```

third-party
information
time

e soprattutto che:

POSSIBILE ≠ PLAUSIBILE ≠ AUTORIZZATO ≠ CONVENIENTE

Per ogni comportamento chiedere sempre:

1. qual è l'osservazione?
2. quale ipotesi suggerisce?
3. quali prerequisiti servono?
4. quale evidenza sarebbe necessaria?
5. qual è il costo/rischio?
6. è nello scope?
7. esiste una strada più semplice?
8. quando ci fermiamo?

Modello di valutazione

Usare questa struttura:

OBSERVATION
HYPOTHESIS
PRECONDITIONS
POSSIBLE TEST
EXPECTED EVIDENCE
IMPACT
COST
RISK
SCOPE
DECISION
STOP CONDITION

La colonna più importante è **DECISION**.

Un buon pentester deve anche sapere decidere:

NON TESTARE

1. Porta tenuta aperta durante l'ingresso

Osservazione

Tra le 08:30 e le 09:00 più persone entrano contemporaneamente e la porta può essere mantenuta aperta per chi segue.

Ipotesi

Possibile debolezza nel controllo fisico degli accessi / tailgating.

Prerequisiti

- presenza fisica;
- capacità di apparire plausibile;
- assenza di controllo reception efficace;
- autorizzazione esplicita per physical security testing.

Potenziale impatto

Accesso non autorizzato ad aree interne.

Decisione didattica

Interessante ma NON testare nel laboratorio standard.

Serve per far capire che una debolezza può essere plausibile ma fuori dallo scope del test tecnico.

2. Pausa sigaretta sul retro

Osservazione

8–10 persone utilizzano regolarmente la stessa area, vicino all'uscita secondaria e ai cassonetti.

Ipotesi A — information gathering

Le conversazioni potrebbero rivelare:

- nomi;
- progetti;
- tecnologie;
- assenze;
- problemi correnti.

Ipotesi B — supporto rimovibile trovato

Un dispositivo USB apparentemente perso potrebbe suscitare curiosità.

Discussione USB

La domanda da far emergere è:

"Una persona inserirebbe davvero nel computer un dispositivo trovato all'esterno?"

Non serve costruire un dispositivo malevolo.

Il test può essere discusso attraverso un **USB innocuo e tracciabile** preparato per l'esercizio, oppure restare completamente teorico.

Possibile evidenza in un engagement autorizzato:

```
dispositivo raccolto?  
dispositivo consegnato all'IT?  
dispositivo ignorato?  
procedura aziendale conosciuta?
```

Punto didattico

Non è sufficiente dire:

```
USB → malware → compromissione
```

Servono molte condizioni intermedie.

Decisione

Plausibile ma con prerequisiti elevati.

Ottimo esempio di attack path che può sembrare brillante ma può risultare meno conveniente di una vulnerabilità web già disponibile.

3. Cassonetti e documenti

Osservazione

Carta ordinaria e materiale del magazzino vengono smaltiti vicino alla zona fumatori.

Ipotesi

Possibile information disclosure tramite documenti impropriamente eliminati.

Informazioni teoricamente utili

- nomi;

- numeri interni;
- fornitori;
- codici prodotto;
- tecnologie;
- procedure.

Controllo compensativo

Esiste un contenitore dedicato alla distruzione sicura.

Decisione

Non assumere vulnerabilità.

La presenza di cassonetti non dimostra che contengano informazioni utili.

Ottimo esercizio per distinguere:

opportunità
vs
evidenza

4. Badge visibili

Osservazione

Alcuni dipendenti tengono il badge al collo anche all'esterno.

Ipotesi

Il badge può rivelare:

- nome;
- azienda;
- ruolo;
- grafica utilizzata;
- struttura del badge.

Possibili usi concettuali

- migliorare un pretext;
- aumentare la credibilità di una comunicazione;
- comprendere il processo di accesso.

Decisione

Information gathering plausibile.

Non implica automaticamente possibilità di clonazione o accesso.

5. Conversazioni nella zona break

Osservazione

Le persone parlano di problemi tecnici e attività operative.

Ipotesi

Le informazioni ascoltate potrebbero aiutare a costruire contesto.

Esempio:

```
"Il CRM non funziona da stamattina"
```

può suggerire che una comunicazione relativa al CRM sarebbe temporalmente plausibile.

Punto didattico

Il valore dell'informazione dipende dal momento.

Questo introduce una nuova dimensione:

```
TIME AS ATTACK SURFACE
```

6. Post-it sulle scrivanie

Osservazione

Esistono post-it con promemoria.

Errore da evitare

```
post-it = password
```

Non è dimostrato.

Ipotesi più corretta

Potrebbero contenere informazioni operative.

Decisione

Bassa priorità senza ulteriori evidenze.

Ottima falsa pista.

7. PC non sempre bloccati

Osservazione

Alcuni utenti non bloccano sempre la postazione durante assenze brevi.

Ipotesi

Una persona già presente fisicamente nell'area potrebbe accedere a una sessione autenticata.

Prerequisiti

Molto elevati:

- presenza interna;
- accesso fisico;
- postazione effettivamente sbloccata;
- assenza del proprietario;
- autorizzazione a testare.

Decisione

Rischio potenzialmente alto, ma costoso e invasivo da validare.

Perfetto per insegnare che impact e test priority non coincidono necessariamente.

8. Stampante condivisa

Osservazione

Documenti rimangono occasionalmente nel vassoio.

Ipotesi

Possibile esposizione accidentale di dati.

Test concettuale

Osservare esclusivamente materiali fittizi predisposti per il laboratorio.

Decisione

Facile da comprendere, ma impatto dipendente dal contenuto.

Non tutto ciò che viene lasciato sulla stampante è sensibile.

9. Lavagne delle sale riunioni

Osservazione

Possono rimanere nomi di progetti, diagrammi e date.

Ipotesi

Information disclosure.

Potenziale concatenazione

```
nome progetto  
→ ricerca documentale  
→ endpoint / repository / comunicazioni più credibili
```

Decisione

Buona superficie informativa, raramente finding critico da sola.

10. Wi-Fi guest comunicata verbalmente

Osservazione

La password della rete guest viene fornita ai visitatori.

Errore comune

```
conosco password guest → ho accesso alla rete corporate
```

Non segue logicamente.

Ipotesi

Serve verificare:

- segmentazione;
- isolamento client;
- accessibilità di risorse interne.

Decisione

La password guest è un'informazione, non una vulnerabilità.

Ottimo collegamento con network segmentation.

11. Corrieri abituali

Osservazione

Alcuni corrieri sono riconosciuti e le interazioni diventano routinarie.

Ipotesi

La familiarità può ridurre il livello di verifica.

Possibile superficie

- pretext fisico;
- consegna di oggetti;
- richiesta di informazioni;
- accesso a zone operative.

Decisione

Plausibile, ma richiede physical/social engineering esplicitamente autorizzato.

12. Tecnici esterni ricorrenti

Osservazione

Il personale conosce alcuni tecnici dei fornitori.

Ipotesi

Un'identità tecnica percepita come legittima può ricevere maggiore fiducia.

Domanda utile

Quali controlli vengono fatti quando un tecnico chiede accesso a un apparato?

Decisione

Superficie di processo molto interessante.

Può introdurre il concetto di supplier impersonation senza eseguire il test.

13. Impresa di pulizie

Osservazione

Gli addetti hanno accesso fisico agli uffici dopo l'orario principale.

Ipotesi

Third-party physical access.

Punto didattico

Non bisogna trasformare automaticamente un fornitore in una minaccia.

La domanda è:

Quali controlli limitano ciò che un terzo può vedere o raggiungere?

Decisione

Utile per threat modeling, non da testare senza autorizzazione specifica.

14. Help desk informale

Osservazione

In caso di urgenza gli utenti contattano direttamente il tecnico.

Ipotesi

Possibile social engineering del processo di supporto.

Domande

- come viene verificata l'identità?
- cosa accade per un reset password?
- esistono callback?
- è richiesto MFA?

Decisione

Molto rilevante come processo.

Non serve fare una chiamata ingannevole: possiamo simulare la richiesta in aula e far disegnare il processo di verifica.

15. Nuovi assunti

Osservazione

I nuovi dipendenti fanno molte domande e i colleghi cercano di aiutarli.

Ipotesi

Un nuovo assunto ha meno conoscenza delle procedure e dei volti.

Possibili rischi

- maggior fiducia verso comunicazioni apparentemente interne;
- difficoltà nel riconoscere richieste insolite;
- onboarding incompleto.

Decisione

Buona superficie umana, ma dipende molto dal contesto.

16. Offboarding

Osservazione

HR comunica la cessazione e IT disabilita gli account.

Ipotesi

Una differenza temporale tra cessazione e revoca potrebbe lasciare accessi attivi.

Categoria

PROCESS / IDENTITY LIFECYCLE

Possibile verifica sicura

Audit documentale su account fittizi o già predisposti.

Decisione

Molto interessante e spesso più realistico di un exploit software.

17. Postazioni condivise in magazzino

Osservazione

Alcune postazioni sono utilizzate da più operatori.

Domanda

Sono condivise le macchine o anche gli account?

Sono due cose diverse.

Ipotesi

Possibile difficoltà di:

- accountability;
- session management;
- least privilege.

Decisione

Da approfondire.

Non chiamarla automaticamente "shared credentials".

18. Email con allegati

Osservazione

Commerciale e amministrazione ricevono molti documenti esterni.

Ipotesi

La natura del lavoro rende plausibili comunicazioni con allegati.

Punto didattico

Un buon scenario di phishing non nasce dal "payload".

Nasce dalla domanda:

Quale comunicazione sarebbe normale per questa persona?

Esempi di contesto, senza esecuzione

```
fattura  
preventivo  
CV  
documentazione corriere
```

presentazione fiera
ordine cliente

Decisione

Superficie significativa.

Nel laboratorio si può valutare la plausibilità dei messaggi senza inviare phishing reale.

19. Cambio IBAN fornitore

Osservazione

Le variazioni bancarie dovrebbero essere verificate.

Ipotesi

Business Email Compromise / process manipulation.

Catena concettuale

conoscenza fornitore
+ comunicazione plausibile
+ procedura debole
→ possibile modifica pagamento

Decisione

Impatto business molto alto, ma non serve eseguire alcuna frode.

Si può testare esclusivamente attraverso tabletop exercise.

20. Messaggio automatico di assenza

Osservazione

Gli utenti possono impostare out-of-office.

Informazioni potenziali

- periodo di assenza;
- sostituto;
- reparto;
- contatti.

Catena possibile

```
persona assente  
→ collega sostituto  
→ richiesta urgente plausibile
```

Decisione

Information source utile, non vulnerabilità autonoma.

21. CEO spesso in mobilità

Osservazione

Il CEO lavora frequentemente via smartphone e viaggia.

Ipotesi

Possibile maggiore esposizione a:

- reti non aziendali;
- comunicazioni urgenti;
- dispositivi mobili;
- perdita/furto del dispositivo.

Decisione

Rischio reale ma troppo generico senza ulteriori evidenze.

22. Eventi e fiere

Osservazione

Il commerciale usa laptop/tablet, scambia contatti e presentazioni e utilizza infrastruttura esterna.

Superfici

```
device  
network  
identity  
documents  
social interaction
```

Decisione

Superficie ampia ma costosa da includere in un engagement breve.

Possibile raccomandazione:

separate assessment / travel security review

23. Social media

Osservazione

Ruoli, eventi e fotografie sono pubblici.

Ipotesi

OSINT può aumentare la qualità di:

- pretext;
- individuazione ruoli;
- conoscenza struttura;
- timing.

Errore da evitare

Informazione pubblica ≠ vulnerabilità.

Decisione

Enabler, non necessariamente finding.

24. Urgenza operativa

Osservazione

Quando qualcosa blocca il lavoro, le persone cercano una soluzione rapida.

Concetto fondamentale

PRESSURE CHANGES BEHAVIOUR

Le condizioni che possono ridurre l'attenzione includono:

- fretta;
- autorità;
- paura di bloccare un processo;
- richiesta apparentemente normale;
- problema già noto.

Decisione

Questa non è una singola vulnerabilità.

È un **moltiplicatore di plausibilità** per altre ipotesi.

25. USB vicino alla zona fumatori — esercizio completo

Questa è l'ipotesi suggerita nell'attività.

Observation

I dipendenti frequentano regolarmente una zona esterna poco presidiata.

Hypothesis

Un supporto rimovibile apparentemente perso potrebbe essere raccolto.

Attenzione

Non assumere:

```
raccolto  
→ inserito  
→ eseguito  
→ compromesso
```

Sono quattro passaggi distinti.

Preconditions

1. qualcuno deve notarlo;
2. qualcuno deve raccoglierlo;
3. deve decidere di collegarlo;
4. endpoint policy deve consentirlo;
5. eventuali controlli devono essere superati;
6. deve esserci una conseguenza utile.

Possible safe test

In un engagement esplicitamente autorizzato si potrebbe usare un dispositivo **totalmente innocuo** con un file informativo e una modalità di tracciamento concordata.

Nel corso è sufficiente un tabletop:

Cosa pensate farebbe l'utente?
Quale policy dovrebbe seguire?
Come potremmo verificarlo senza rischio?

Cost

Medio/alto.

Operational risk

Maggiore di molti test web.

Decision

Buona ipotesi per il threat model, non necessariamente buona priorità per un pentest breve.

Questo è il messaggio che vogliamo far emergere.

26. Quando una superficie NON vale la pena

Far trovare agli studenti almeno tre casi.

Esempi:

Parcheggio

Sapere dove parcheggia un dipendente può avere scarsissimo valore nell'engagement.

DECISION: NO TEST

Smartphone personali durante la pausa

Informazione troppo generica.

Senza ulteriori evidenze:

DECISION: NEEDS MORE EVIDENCE

Post-it

Possibile informazione, ma nessuna evidenza di password.

DECISION: LOW PRIORITY

27. Collegare umano e tecnico

La parte più importante del laboratorio è far capire che le superfici non vivono isolate.

Esempio:

```
SOCIAL MEDIA
↓
ruolo dipendente

OUT-OF-OFFICE
↓
assenza responsabile

HELP DESK INFORMALE
↓
processo di verifica debole

IDENTITY
↓
account reset
```

Non dobbiamo eseguire questa catena.

Dobbiamo far vedere che **gli indizi possono concatenarsi**.

Altro esempio:

```
ADMIN STAGING
↓
nome applicazione

CONVERSAZIONE BREAK
↓
"oggi il CRM non funziona"

EMAIL PLAUSIBILE
↓
contesto credibile
```

Questo è attack surface thinking.

28. Matrice docente

Osservazione	Categoria	Plausibilità	Costo test	Valore didattico	Decisione
porta tenuta aperta	physical	media	alta	alta	discutere
pausa fumatori	human/physical	media	media	alta	tabletop
USB trovato	human/endpoint	incerta	medio-alta	alta	tabletop
cassonetti	information	incerta	media	alta	discutere
badge visibile	information	alta	bassa	alta	osservazione
post-it	information	bassa	media	alta	falsa pista
PC sbloccato	physical/session	media	alta	alta	non testare
stampante	information	media	bassa	media	simulabile
lavagna	information	alta	bassa	media	simulabile
guest Wi-Fi	network	alta	bassa	alta	verificare segmentazione solo se scope
corrieri	third-party	media	alta	alta	tabletop
help desk	process/identity	alta	media	molto alta	simulare processo
offboarding	identity/process	media	bassa	molto alta	audit fittizio
shared workstation	identity	media	bassa	alta	approfondire
allegati email	human	alta	media	alta	tabletop
cambio IBAN	process	media	alta	molto alta	tabletop
out-of-office	information	alta	bassa	alta	OSINT concept
social media	OSINT	alta	bassa	alta	osservazione
urgenza	human/process	alta	n/a	molto alta	moltiplicatore

29. Debrief consigliato

Alla fine chiedere:

Qual è stata la vulnerabilità più importante che avete trovato?

Se rispondono subito con una tecnica, riportarli al ragionamento:

Quale combinazione di persona, processo e tecnologia produceva il rischio?

Poi:

1. quale comportamento sembrava attaccabile ma non lo era realmente?
2. quale attacco avrebbe richiesto troppo sforzo?
3. quale informazione era utile ma non costituiva una vulnerabilità?
4. quale controllo umano o procedurale spezzava una possibile chain?
5. quale superficie non tecnica avreste prioritizzato e perché?
6. quale test avreste rifiutato perché troppo invasivo?
7. quale ipotesi poteva essere verificata con una prova innocua?

30. Messaggio finale

Scrivere alla lavagna:

```
ATTACK SURFACE  
≠  
ELENCO DI PORTE
```

Poi:

```
ATTACK SURFACE =  
persone  
+ processi  
+ identità  
+ informazioni  
+ spazi  
+ fornitori  
+ tecnologia  
+ tempo
```

E infine:

Il lavoro del pentester non è cercare un exploit ovunque. È capire dove un insieme di condizioni può produrre un rischio reale, scegliere cosa vale la pena verificare e fermarsi quando l'evidenza è sufficiente.